

Ethical Hacking Practicals

Semester VIII: Discipline Specific Elective

Student Name: Ankit Kumar
Roll No. : 22035570007
Date of Submission: 28/04/2026

Practicals List Overview

Practical No.	Title	Status
P1	Introduction to Vulnerabilities and OWASP Top 10	In Progress
P2	Network Scanning and Reconnaissance	In Progress
P3	Password Cracking (Test Environment)	In Progress
P4	Metasploit Basics	In Progress
P5	Alternate Data Streams (ADS)	In Progress
P6	SQL Injection (Test Environment)	In Progress
P7	Framework Mapping (NIST/Cyber Kill Chain)	In Progress

Practical No.	Title	Status
P8	Vulnerability Assessment Report (OpenVAS)	Pending Scan Report

Practical Details

P1: Introduction to Vulnerabilities and OWASP Top 10

- **Objective:** Set up a local installation of OWASP Juice Shop or DVWA on a virtual machine and identify vulnerabilities.
- **Tools Used:** VirtualBox, OWASP Juice Shop.
- **Observations:** Identify vulnerabilities such as SQL Injection or Cross-Site Scripting (XSS).
- **Commands Used:**
 - **Setup (Docker Pull):** ``docker pull bkimminich/juice-shop``
 - **Run (Docker):** ``docker run -d -p 3000:3000 bkimminich/juice-shop``

1234

FileEditViewAnalyseReportToolsImportExportOnlineHelp

Standard Mode

Sites

Default Context

Sites

- > http://cdnjs.cloudflare.com
- > https://firefox-settings-attack
- > https://www.herokucdn.com
- > http://juice-shop.herokuapp.com
 - GET:._darcs
 - GET:.bzip
 - GET:.hg
 - GET:/
 - GET:BitKeeper
 - GET:Materialcons-Regular.ttf
 - GET:Materialcons-Regular.woff
 - GET:Materialcons-Regular.woff2
- > api

Quick Start

Request

Response

<

This screen allows you to launch an automated attack on a website.

Please be aware that you should only attack websites that you own or have permission to test.

URL to attack:

http://juice-shop.herokuapp.com

Use traditional spider:

☒

Use ajax spider:

If Modern

Attack

Progress:

Attack complete

History

Search

Alerts

Output

Spider

AJAX Spider

Active

New Scan

Progress: 0: http://juice-s...herokuapp.com/

||

Sent Messages

Filtered Messages

ID	Req. Timestamp	Resp. Timestamp	Method
254	2/27/26, 3:08:38 PM	2/27/26, 3:08:42 PM	GET
256	2/27/26, 3:08:42 PM	2/27/26, 3:08:46 PM	GET
258	2/27/26, 3:08:46 PM	2/27/26, 3:08:51 PM	GET
260	2/27/26, 3:08:51 PM	2/27/26, 3:08:55 PM	GET
262	2/27/26, 3:08:55 PM	2/27/26, 3:08:59 PM	GET
264	2/27/26, 3:08:59 PM	2/27/26, 3:09:04 PM	GET
266	2/27/26, 3:09:04 PM	2/27/26, 3:09:09 PM	GET
268	2/27/26, 3:09:09 PM	2/27/26, 3:09:13 PM	GET
270	2/27/26, 3:09:13 PM	2/27/26, 3:09:17 PM	GET
272	2/27/26, 3:09:17 PM	2/27/26, 3:09:21 PM	GET
274	2/27/26, 3:09:21 PM	2/27/26, 3:09:26 PM	GET

P2: Network Scanning and Reconnaissance

- **Objective:** Explore network configurations and perform scanning on a local network.
- **Tools Used:** Nmap, Wireshark, ipconfig.
- **Activity:** Analyzed network traffic using pre-captured .pcap files from public sources.
- **Commands Used:**
 - **Windows IP Config:** `ipconfig /all`
 - **Linux IP Config:** `ifconfig`
 - **Basic Network Scan (Nmap):** `nmap -sn [Target IP Range]`
 - **Service/Version Scan (Nmap):** `nmap -sV -p [port] [Target IP]`
- **Documentation:**

(kali㉿kali)-[~/Documents]

\$ nmap -p 20,21,25,53,80

Starting Nmap 7.95 (<https://nmap.org>) at 2026-02-10 13:57 EST

WARNING: No targets were specified, so 0 hosts scanned.

Nmap done: 0 IP addresses (0 hosts up) scanned in 0.06 seconds

(kali㉿kali)-[~/Documents]

\$ nmap -p 20,21,25,53,80 192.168.43.5

Starting Nmap 7.95 (<https://nmap.org>) at 2026-02-10 13:57 EST

Nmap scan report for Insane_nitish (192.168.43.5)

Host is up (0.00090s latency).

PORT	STATE	SERVICE
20/tcp	filtered	ftp-data
21/tcp	filtered	ftp
25/tcp	filtered	smtp
53/tcp	filtered	domain
80/tcp	filtered	http

Nmap done: 1 IP address (1 host up) scanned in 1.70 seconds

\$ nmap -sV 192.168.43.5

Starting Nmap 7.95 (<https://nmap.org>) at 2026-02-10 13:52 EST

Nmap scan report for Insane_nitish (192.168.43.5)

Host is up (0.0044s latency).

Not shown: 991 filtered tcp ports (no-response)

PORT	STATE	SERVICE	VERSION
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
445/tcp	open	microsoft-ds?	
2869/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
3306/tcp	open	mysql	MySQL 8.0.36
4343/tcp	open	ssl/unicall?	
4449/tcp	open	ssl/privatewire?	
5432/tcp	open	postgresql	PostgreSQL DB 9.6.0 or later
6646/tcp	open	unknown	

Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at <https://nmap.org>

Nmap done: 1 IP address (1 host up) scanned in 184.96 seconds

```

(kali㉿kali)-[~/Documents]
└─$ nmap 192.168.43.5
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-10 13:50 EST
Nmap scan report for Insane_nitish (192.168.43.5)
Host is up (0.0055s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
2869/tcp   open  icslap
3306/tcp   open  mysql
4343/tcp   open  unicall
4449/tcp   open  privatewire
5432/tcp   open  postgresql
6646/tcp   open  unknown

Nmap done: 1 IP address (1 host up) scanned in 6.10 seconds

```

```

(kali㉿kali)-[~/Documents]
└─$ nmap -sS 192.168.43.5
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-10 13:50 EST
Nmap scan report for Insane_nitish (192.168.43.5)
Host is up (0.0037s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
2869/tcp   open  icslap
3306/tcp   open  mysql
4343/tcp   open  unicall
4449/tcp   open  privatewire
5432/tcp   open  postgresql
6646/tcp   open  unknown

Nmap done: 1 IP address (1 host up) scanned in 5.68 seconds

```

```
(kali㉿kali)-[~/Documents]
$ whois du.ac.in
Domain Name: du.ac.in
Registry Domain ID: D13836-IN
Registrar URL: http://www.ernet.in
Updated Date: 2024-05-06T12:14:57.903Z
Creation Date: 2004-02-28T05:00:00.039Z
Registry Expiry Date: 2028-02-28T05:00:00.000Z
Registrar: ERNET India
Registrar IANA ID: 800068
Registrar Abuse Contact Email: tejalt@eis.ernet.in
Registrar Abuse Contact Phone: +91.1123358248
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Registry Registrant ID: REDACTED FOR PRIVACY
Registrant Name: REDACTED FOR PRIVACY
Registrant Organization: Delhi University Computer Centre
Registrant Street: REDACTED FOR PRIVACY
Registrant City: REDACTED FOR PRIVACY
Registrant State/Province:
Registrant Postal Code: REDACTED FOR PRIVACY
Registrant Country: IN
Registrant Phone: REDACTED FOR PRIVACY
```

P3: Password Cracking (Test Environment)

- **Objective:** Crack simple password hashes generated using online tools.
- **Tools Used:** John the Ripper.
- **Note:** Specifically utilizing John the Ripper for this exercise as per project requirements; Hashcat was not utilized.
- **Commands Used:**
 - **Prepare Hashes (unshadow):** ``unshadow /etc/passwd /etc/shadow > mypasswd.txt``
 - **Crack Passwords (Wordlist):** ``john --wordlist=/path/to/wordlist.txt mypasswd.txt``
- **Documentation:**


```
Session Actions Edit View Help
└─$ nano dict.txt

(kali㉿kali)-[~/eh]
└─$ ls
dict.txt  sane.txt

(kali㉿kali)-[~/eh]
└─$ nano sane.txt

(kali㉿kali)-[~/eh]
└─$ john --wordlist=dict.txt sane.txt
Warning: detected hash type "LM", but the string is also recognized as "dynamic"
Use the "--format=dynamic-md5($p)" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "HAVAL"
Use the "--format=HAVAL-128-4" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "MD2"
Use the "--format=MD2" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "mdc2"
Use the "--format=mdc2" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "mscash"
Use the "--format=mscash" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "mscash2"
Use the "--format=mscash2" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "NT"
Use the "--format=NT" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD4"
Use the "--format=Raw-MD4" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD5"
Use the "--format=Raw-MD5" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD5u"
Use the "--format=Raw-MD5u" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-SHA1-AxCrypt"
Use the "--format=Raw-SHA1-AxCrypt" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "ripemd-128"
Use the "--format=ripemd-128" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Snefru-128"
Use the "--format=Snefru-128" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "ZipMonster"
Use the "--format=ZipMonster" option to force loading these as that type instead
Using default input encoding: UTF-8
Using default target encoding: CP850
Loaded 2 password hashes with no different salts (LM [DES 256/256 AVX2])
Warning: poor OpenMP scalability for this hash type, consider --fork=2
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 1 candidate left, minimum 512 needed for performance.
0g 0:00:00:00 DONE (2026-03-20 06:38) 0g/s 25.00p/s 25.00c/s 50.00C/s HELLO12
Session completed.

(kali㉿kali)-[~/eh]
```


P4: Metasploit Basics

- **Objective:** Practice gaining access using the Metasploit Framework on a vulnerable VM.
- **Environment:** Metasploitable2.
- **Commands Used (in msfconsole):**
 - **Search Exploit:** ``search [vulnerability]``
 - **Set Target:** ``set RHOSTS [Target IP]``
 - **Execute:** ``exploit`` or ``run``
- **Documentation:**

```

(kali㉿kali)-[~]
└─$ nmap -sV 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-01 18:02 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0052s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rrexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:CC:5A:75 (PCS Systemtechnik/Oracle VirtualBox virtual M
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs

Service detection performed. Please report any incorrect results at https://nmap.org
Nmap done: 1 IP address (1 host up) scanned in 12.32 seconds

```

```

(kali㉿kali)-[~]
└─$ nmap 10.0.2.15
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-01 17:45 EDT
Nmap scan report for 10.0.2.15
Host is up (0.0000020s latency).
All 1000 scanned ports on 10.0.2.15 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 0.23 seconds

```

```
(kali㉿kali)-[~]  
$ ftp 192.168.56.102  
Connected to 192.168.56.102.  
220 (vsFTPD 2.3.4)  
Name (192.168.56.102:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> █
```

P5: Alternate Data Streams (ADS)

- **Objective:** Practice creating ADS on a Windows VM to hide files and explore detection techniques.
- **Tools Used:** Windows VM, Command Prompt.
- **Commands Used (Command Prompt):**
 - **Create ADS:** ``echo "Hidden content" > visible_file.txt:hidden_stream.txt``
 - **View ADS Existence:** ``dir /r``
 - **View ADS Content:** ``more < visible_file.txt:hidden_stream.txt``
- **Documentation:**

```
C:\Users\nitis>cd C:\Users\nitis\OneDrive\Desktop\A
C:\Users\nitis\OneDrive\Desktop\All Desktop\College
C:\Users\nitis\OneDrive\Desktop\All Desktop\College
C:\Users\nitis\OneDrive\Desktop\All Desktop\College
C:\Users\nitis\OneDrive\Desktop\All Desktop\College
Volume in drive C is Acer
Volume Serial Number is BCBC-FFED

Directory of C:\Users\nitis\OneDrive\Desktop\All D

03-04-2026  18:20    <DIR>          .
03-04-2026  18:19    <DIR>          ..
03-04-2026  18:20                  14 normal.txt
                1 File(s)                14 bytes
                2 Dir(s)  34,644,639,744 bytes free

C:\Users\nitis\OneDrive\Desktop\All Desktop\College
```

```
C:\Users\nitis>cd C:\Users\nitis\OneDrive\Desktop\A
```

```
C:\Users\nitis\OneDrive\Desktop\All Desktop\College
```

```
C:\Users\nitis\OneDrive\Desktop\All Desktop\College
```

```
C:\Users\nitis\OneDrive\Desktop\All Desktop\College
```

```
C:\Users\nitis\OneDrive\Desktop\All Desktop\College
```

```
Volume in drive C is Acer
```

```
Volume Serial Number is BCBC-FFED
```

```
Directory of C:\Users\nitis\OneDrive\Desktop\All D
```

```
03-04-2026 18:20 <DIR>
```

```
.
```

```
03-04-2026 18:19 <DIR>
```

```
..
```

```
03-04-2026 18:20 14 normal.txt
```

```
1 File(s) 14 bytes
```

```
2 Dir(s) 34,644,639,744 bytes free
```

```
C:\Users\nitis\OneDrive\Desktop\All Desktop\College
```

```
C:\Users\nitis\OneDrive\Desktop\All Desktop\College
```

```
Volume in drive C is Acer
```

```
Volume Serial Number is BCBC-FFED
```

```
Directory of C:\Users\nitis\OneDrive\Desktop\All D
```

```
03-04-2026 18:20 <DIR>
```

```
.
```

```
03-04-2026 18:19 <DIR>
```

```
..
```

```
03-04-2026 18:21 14 normal.txt
```

```
1 File(s) 14 bytes
```

```
2 Dir(s) 34,639,044,608 bytes free
```

```
C:\Users\nitis\OneDrive\Desktop\All Desktop\College
```

```

C:\Users\nitis\OneDrive\Desktop\All Desktop\College
Volume in drive C is Acer
Volume Serial Number is BCBC-FFED

Directory of C:\Users\nitis\OneDrive\Desktop\All D

03-04-2026  18:20    <DIR>          .
03-04-2026  18:19    <DIR>          ..
03-04-2026  18:21                14 normal.txt
                                11 normal.txt:hidd
                                14 bytes
                1 File(s)
                2 Dir(s)  34,645,946,368 bytes free

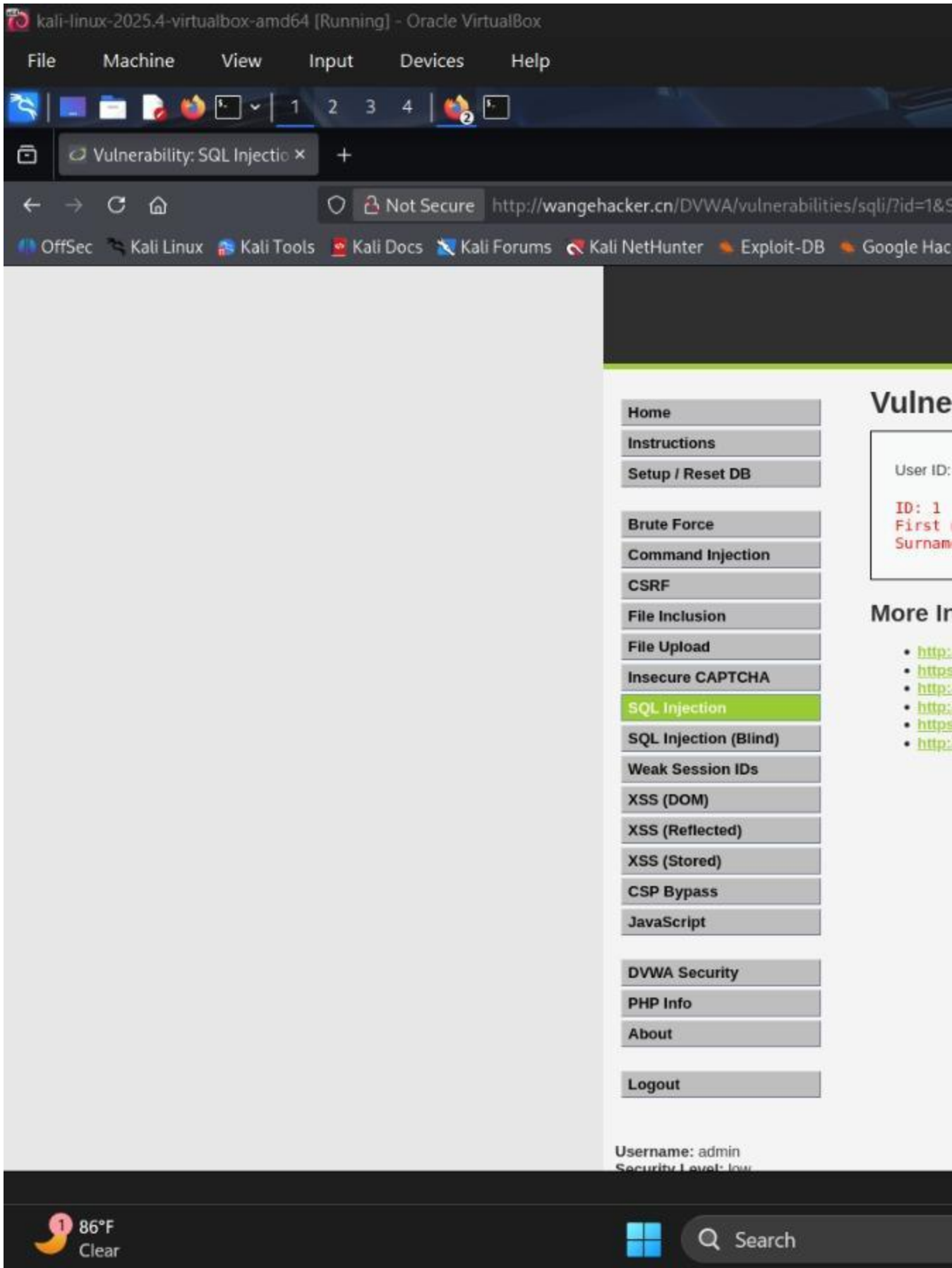
C:\Users\nitis\OneDrive\Desktop\All Desktop\College

```

P6: SQL Injection (Test Environment)

- **Objective:** Perform SQL Injection to extract sample data and understand mitigation strategies.
- **Environment:** DVWA / OWASP Juice Shop.
- **Commands Used (In browser/request):**
 - **Test Payload (Basic bypass):** ` ' OR 1=1 --`
 - **Data Extraction (Union Attack):** ` ' UNION SELECT 1, database(), version() --`
- **Documentation:**

Q Search





Vulnerability: SQL Injectio x +



Not Secure

http://wangehacker.cn/DVWA/vulnerabilities/sql

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Go

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

DVWA Security

PHP Info

About

Logout

Username: admin
Security Level: low





Vulnerability: SQL Injectio x +



Not Secure

http://wangehacker.cn/DVWA/vulnerabilities/sql

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Go

- Home
- Instructions
- Setup / Reset DB
- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection**
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript
- DVWA Security
- PHP Info
- About
- Logout

Username: admin
Security Level: low



Search



Vulnerability: SQL Injectio x +



Not Secure

http://wangehacker.cn/DVWA/vulnerabilities/sql

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Go

- Home
- Instructions
- Setup / Reset DB
- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection**
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript
- DVWA Security
- PHP Info
- About
- Logout



P7: Framework Mapping

- **Objective:** Map a security incident to the NIST Cybersecurity Framework or the Cyber Kill Chain.
- **Task:** Prepare a simple report outlining the various stages of the attack.

Report: Operation Shadow Access

1. Incident Description

Operation Shadow Access was a sophisticated, multi-stage credential harvesting campaign aimed at long-term corporate espionage. The attacker used a reverse-proxy phishing framework (e.g., Evilginx2 or Modlishka) on a typosquatted domain with a valid SSL certificate to bypass traditional Multi-Factor Authentication (MFA) by capturing real-time session cookies. By performing a "pass-the-cookie" attack, the adversary gained a valid session in the company's Azure AD / Microsoft 365 environment, which was then used for lateral movement to target source code repositories and financial databases.

- **Key Outcomes:** Unauthorized access, sensitive data access, privilege escalation, and critical system compromise.

2. Cyber Kill Chain Mapping

The attack followed these stages:

- **Reconnaissance:** Passive Open Source Intelligence (OSINT) tools like Maltego and the Harvester were used to map corporate hierarchy and scrape LinkedIn to identify high-value targets (e.g., Senior DevOps Engineer) with high-level access.
- **Weaponization:** A fake login portal was designed for credential harvesting, and the link was embedded in a phishing email for high deliverability.
- **Delivery:** A seemingly legitimate phishing email (like a password reset alert) was sent to the employee.
- **Exploitation:** Human trust was exploited through classic social engineering; no technical vulnerability was utilized.
- **Installation:** Instead of malware, stolen credentials and access scripts were stored to execute command-line actions and elevate privileges later.
- **Command and Control (C2):** Persistent access was maintained via remote login using the valid stolen credentials, making detection difficult.

- **Actions on Objectives:** The goal of data theft and system disruption was achieved by accessing confidential files, escalating privileges to administrator level, and modifying system configurations.

3. NIST Cybersecurity Framework Mapping

This assessment identifies failures and required responses:

- **Identify**
 - *Failure:* No classification of high-risk user accounts and lack of monitoring for sensitive system access.
 - *Required Action:* Identify critical assets/privileged users and maintain an asset inventory.
- **Protect**
 - *Failure:* No Multi-Factor Authentication (MFA) and weak email filtering.
 - *Required Action:* Enable MFA for all users and improve phishing protection systems.
- **Detect**
 - *Failure:* Unauthorized login not detected and no alerts for unusual login locations.
 - *Required Action:* Implement login anomaly detection and use SIEM tools to establish baselines for normal user behavior.

P8: Vulnerability Assessment Report

- **Objective:** Perform a basic vulnerability assessment on a test VM.
- **Tools Used:** OpenVAS.
- **Status:** Awaiting the final scan report to be appended to this section.
- **Commands Used:**
 - **Start Greenbone/OpenVAS (CLI):** ``gvm-start``
- **Documentation:**